

CSIT302 Cybersecurity

Day 3-2 – Laws and Regulations

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Outline

- Introductory
- General Data Protection Regulation
- Australian Privacy Act 1988
- Cyber Security Act 2024

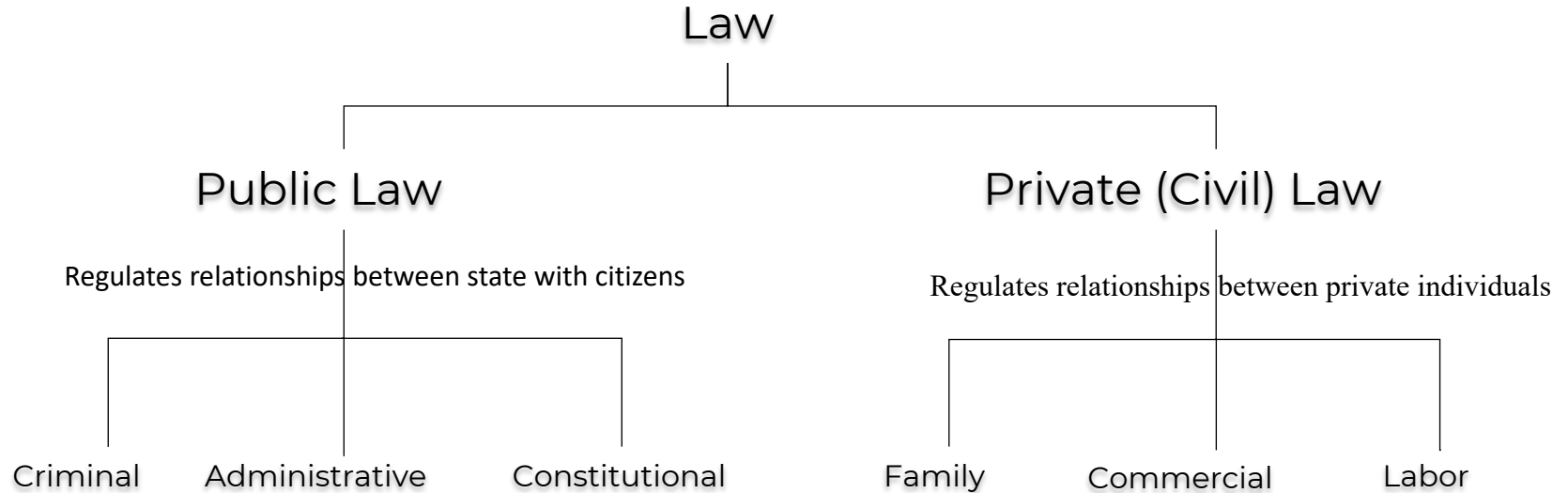
Introduction

- What is law?
- Law is a collection of rules which govern our society. It is used to mandate or prohibit certain behaviour.
- Laws are drawn from **ethics**, which define socially acceptable behaviours. Ethics in turn are based on **cultural mores**, which are the fixed moral attitudes or customs of a particular group.
- The key difference between laws and ethics is that laws carry the authority of a governing body, and ethics do not.

Policy VS Law

- Policy is established and enforced within a company to help maintain security.
- **Policies**
 - are guidelines that describe acceptable and unacceptable employee behaviors in the workplace
 - function as organizational laws, complete with penalties, judicial practices, and sanctions to require compliance.
- Unlike laws, policies are not legally binding but serve as frameworks for decision-making and action.

Categories of Law



What is cyber law?

- Cyber laws encompass the framework and regulations related to protecting computer systems, networks and data from cyberattacks and relevant attacks.
- Cybersecurity laws seek to address:
 - Privacy and Data Protection
 - Intellectual Property Protection
 - Cybersecurity and Cybercrime
 - E-Commerce and Online Contracts
 - Internet Governance
 - Liability and Responsibility
 - ...

Types of Cyber Laws

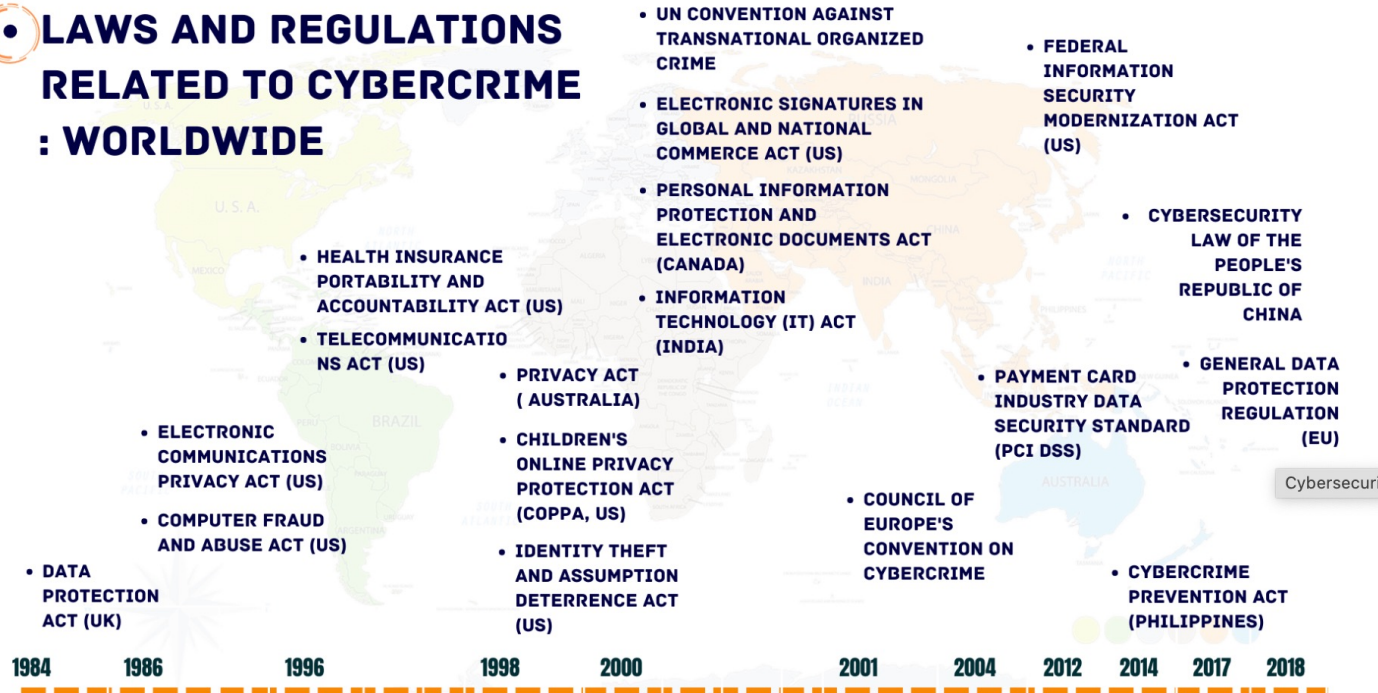
- Privacy Laws
- Data Protection Laws
- Copyright and Intellectual Property Laws
- E-commerce Laws
- Cybercrime Laws
- ...

Cybersecurity Global Laws

- Council of Europe's Convention on Cybercrime
- UN Convention against Transnational Organized Crime
- Computer Fraud and Abuse Act (US)
- Electronic Communications Privacy Act (US)
- Identity Theft and Assumption Deterrence Act (US)
- **General Data Protection Regulation (EU)**
- Federal Information Security Modernization Act (US)
- Health Insurance Portability and Accountability Act (US)
- Payment Card Industry Data Security Standard (PCI DSS)
- Children's Online Privacy Protection Act (COPPA, US)
- Telecommunications Act (US)
- Electronic Signatures in Global and National Commerce Act (US)
- Data Protection Act (UK)
- Australian Privacy Act
- Personal Information Protection and Electronic Documents Act (Canada)
- Cybercrime Prevention Act (Philippines)
- Information Technology (IT) Act (India)
- Cybersecurity Law of the People's Republic of China

Key Cybersecurity Global Laws

• LAWS AND REGULATIONS RELATED TO CYBERCRIME : WORLDWIDE



General Data Protection Regulation (GDPR)

- Effect on 25th May 2018
- Made by European Union (EU)
- **Purpose:**
 - It outlines a new set of enforceable and uniform requirements for protecting the **personal data** of individuals across the EU.
- The GDPR will levy harsh fines against those who violate its privacy and security standards, with penalties reaching into the tens of millions of euros.

What are protected by GDPR?

- The GDPR protects **personal data** of individuals in EU.
- Personal data
 - Any data any information relating to an identified or identifiable natural person ('data subject'); An identifiable natural person is one who can be identified, directly or indirectly;
 - Include a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;
- The GDPR applies to the processing of personal data, whether automated or not, such as collecting, storing, organizing, etc.
- Exception: it does not apply to the processing of personal data
 - By a natural person in the course of a purely personal or household activity.

Territorial Scope of GDPR

- The territorial scope of GDPR bases on the two main criteria:
 1. the establishment of a controller or a processor in the EU; or
 2. being active on the EU market by **offering services or goods** or **monitoring behavior**.
- Terms:
 - **Controller**: the party who determines the purposes and means of the processing of personal data.
 - **Processor**: the party who processes personal data on behalf of the controller.
 - A person, a public authority, agency or other body can either be controller or processor.

Key Principles of GDPR (Article 5)

1. Lawfulness, fairness and transparency
2. Purpose limitation
3. Data minimization
4. Accuracy
5. Storage limitation
6. Integrity and Confidentiality
7. Accountability

Key Principles of GDPR

1. Lawfulness, fairness and transparency

- **Lawfulness** means that you don't do anything with the personal data which is unlawful in a more general sense, which includes statute and common law obligations.
 - ✓ Lawful basis should be determined for the data processing activity.
- **Fairness** means the data subject must reasonably expect the processing and the processing mustn't have unjustified adverse effects on them.
- **Transparency** means being clear, open and honest with people from the start about who you are, how and why you use their personal information, and their rights.

Key Principles of GDPR

2. Purpose limitation

- The personal data shall be collected for specified, explicit and legitimate purposes and **not further processed in a manner that is incompatible with those purposes.**
- In practice, this means that you must:
 - ✓ be clear from the outset why you are collecting personal data and what you intend to do with it;
 - ✓ comply with your documentation obligations to specify your purposes;
 - ✓ comply with your transparency obligations to inform individuals about your purposes; and
 - ✓ ensure that if you plan to use or disclose personal data for any purpose that is additional to or different from the originally specified purpose, the new use is fair, lawful and transparent.

Key Principles of GDPR

3. Data minimization

- The personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed .
- The organization should identify the minimum amount of data that it needs to fulfil its purpose.
- For example, a recruitment agency collecting applicants' health conditions that are only relevant to particular manual occupations for an office job does not satisfy data minimization.

Key Principles of GDPR

4. Accuracy

- Personal Data must be
 - ✓ accurate
 - ✓ kept up to date
 - ✓ erased or rectified without delay when they are inaccurate
- The GDPR does not define the word 'accurate'. However, the Data Protection Act 2018 does say that 'inaccurate' means "incorrect or misleading as to any matter of fact".
- In practice, this means that you must:
 - ✓ take reasonable steps to ensure the accuracy of any personal data;
 - ✓ ensure that the source and status of personal data is clear;
 - ✓ carefully consider any challenges to the accuracy of information; and
 - ✓ consider whether it is necessary to periodically update the information.

Key Principles of GDPR

5. Storage limitation

- Personal data shall be kept in a form which permits identification of data subjects **for no longer than is necessary for the purposes** for which the personal data are processed;
- personal data may be stored for longer periods solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes.
- You cannot keep the data longer than you actually need it.

Key Principles of GDPR

7. Integrity and confidentiality

- You must ensure that you have appropriate security measures in place to protect the personal data you hold.
- Data must be processed in **a manner that ensures appropriate security of the personal data**,
 - ✓ including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage,
 - ✓ using appropriate technical or organisational measures.
- Examples of technical measures:
 - ✓ Two-factor authentication or encryption
- Examples of organisational measures
 - ✓ Staff training or security policy

Key Principles of GDPR

- 8. Accountability

- The controller shall be responsible for and be able to demonstrate compliance with all other principles mentioned above.
- The controller must have appropriate measures and records in place to demonstrate compliance. For example, measures include
 - ✓ adopting policy and procedure
 - ✓ taking a 'data protection by design and default' approach
 - ✓ implementing appropriate security measures
 - ✓ ...
- Accountability obligations are on-going. Data controllers must review and, where necessary, update the measures they have in place.

Rights of the Data Subjects

- Data subjects' privacy rights:
 - The right to be informed
 - The right of access
 - The right to rectification
 - The right to erasure
 - The right to restrict processing
 - The right to data portability
 - The right to object
 - Rights in relation to automated decision making and profiling

Data Transfers to Third Countries or International Organisations

- The GDPR imposes restrictions on the transfer of personal data outside the EU, to non-EU countries or international organisations, to ensure that the level of protection of individuals granted by the GDPR remains the same.
- General Principles for Data Transfers
 - **Any transfer of personal data** which are undergoing processing or are intended for processing after transfer to a third country or to an international organisation must subject to:
 - ✓ **the GDPR**
 - ✓ **the conditions are complied with by the controller and processor**, including for onward transfers of personal data from the third country or an international organisation to another third country or to another international organisation.

Cross-border Transfer of Data

- Transfers on the basis of an adequacy decision (Under Article 45),
 - a transfer of personal data to non-EU countries or organisations can only take place where the European Commission has decided that the receiving country or organisation has an **adequate level of protection**.
 - If the protection level is inadequate upon review, the Commission may repeal the country's status without retroactive effect.
 - Currently, Australia has not been recognised as providing adequate protection for the purposes of Article 45.
- Transfers subject to appropriate safeguards.
 - Tools that can be used like Standard data protection clauses, Binding Corporate Rules, etc.

GDPR Breaches and Fines

- Any organization that is not GDPR compliant, regardless of its size, faces a significant liability.
- The fines imposed by the GDPR under Article 83 are flexible and scale with the firm.
- Under GDPR, fines has two tiers:
 - **The less severe infringements** could result in a fine up to €10 million or 2% of their global annual turnover, whichever is higher;
 - **The more serious infringements** could result in a fine up to €20 million or 4% of their global annual turnover, whichever is higher;

GDPR Breaches and Fines

- How are the fines administered?
 - Fines are administered by **the data protection regulator** in each EU country.
 - That authority will determine whether an infringement has occurred and the severity of the penalty.
 - They will use the following 10 criteria to determine whether a fine will be assessed and in what amount:
 - ✓ Gravity and nature
 - ✓ Intention
 - ✓ Mitigation
 - ✓ Precautionary measures
 - ✓ History
 - ✓ Cooperation
 - ✓ Data category
 - ✓ Notification
 - ✓ Certification
 - ✓ Aggravating/mitigating factors

Real World Data Breaches and Fine Example

- Facebook (now Meta) was fined a record of €1.2 billion by **Ireland's Data Protection Commission** for breaching European Union (EU) privacy rules in May 2023.
- Reasons for the fine:
 - Meta Ireland infringed Article 46(1) **GDPR** when it continued to transfer personal data from the European Union/European Economic Area to the USA.
 - The Court of Justice of the European Union ruled that data transfers to the United States did not guarantee an adequate level of protection for the fundamental rights of European individuals. In its ruling, the Irish regulator concluded that Meta had not taken appropriate measures to protect users' personal data and had not provided sufficient guarantees for the protection of fundamental rights. The US legislation does not guarantee a level of data protection equivalent to that provided by European legislation.
- Lesson learnt.
 - marks a significant turning point in the field of personal data protection
 - sends a clear message to major technology companies about the importance of complying with data confidentiality and security rules.

Australian Cybersecurity Policy

- Cybersecurity Policy Then & Now
- National Strategy to Secure Cyberspace
- Critiques of the National Plan
- Discussion Activity

Government's Cybersecurity Then & Now

Government's Cybersecurity: Then

- In 1979
 - Telecommunications (Interception and Access) Act 1979
- In 1988
 - Privacy Act 1988
- In 1995
 - Criminal Code Act 1995
- In 1997
 - Telecommunications Act 1997

Government's Cybersecurity: Now

- In 2015

- Telecommunications (Interception and Access) Act 1979



Amended

- Telecommunications (Interception and Access) Amendment (Data Retention) Act 2015.

- In 2024

- Cyber Security Act 2024

Australian Privacy Act 1988

- Privacy Act 1988

- The principal piece of Australian legislation protecting the handling of personal information about individuals.
- This includes the collection, use, storage and disclosure of personal information in the federal public sector and in the private sector.
- It has many amendments over the years, e.g.,
 - ✓ in 1991, 1994, 2000, 2001, 2010, 2011, 2018, 2022

Australian Privacy Act 1988

- Privacy act 1988 sets out 13 Australian Privacy Principles (APPs), which are the cornerstone of the privacy protection framework in it.
- The **13 Australian Privacy Principles** (APPs) govern standards, rights and obligations around:
 - the collection, use and disclosure of personal information
 - an organisation or agency's governance and accountability
 - integrity and correction of personal information
 - the rights of individuals to access their personal information.

Australian Privacy Act 1988 (Cont'd)

- The **Australian Privacy Principles** are principles-based law.
 - This gives an organisation or agency flexibility to tailor their personal information handling practices to their business models and the diverse needs of individuals.
- They are also technology neutral, which allows them to adapt to changing technologies.
- A breach of an APP is an 'interference with the privacy of individual' and can lead to regulatory action and penalties.

Australian Privacy Principles

Part 1: Consideration of personal Information Privacy

- **APP1: open and transparent management of personal information**

The objective of APP1 is to ensure that APP entities manage personal information in an open and transparent way.

An APP entity must have a clearly expressed and up to date policy (the APP privacy policy) about the management of personal information by the entity.

- **APP2: anonymity and pseudonymity**

➤ Individuals must have the option of not identifying themselves, or of using a pseudonym, when dealing with an APP entity in relation to a particular matter.

Australian Privacy Principles

Part 2: Collection of personal information

- **APP3: collection of solicited personal information**

- The objective of APP1 is to ensure that APP entities manage personal information in an open and transparent way.
- An APP entity must have a clearly expressed and up to date policy (the APP privacy policy) about the management of personal information by the entity.

- **APP4: dealing with unsolicited personal information**

- Individuals must have the option of not identifying themselves, or of using a pseudonym, when dealing with an APP entity in relation to a particular matter.

- **APP5: notification of the collection of personal information**

- Entity that collects information about individual must notify and ensure that the individual is aware of the matters.

Australian Privacy Principles

Part 3: Dealing with personal information

- **APP6: use or disclosure of personal information**

- Specify how the entity can use or disclose collected personal information

- **APP7: direct marketing**

- The collected personal information must not use for direct marketing except for some special cases.

- **APP8: cross-border disclosure of personal information**

- Outlines the requirements for disclosing personal information to other countries.

- **APP9: adoption, use or disclosure of government related identifiers**

- Specify the conditions of how the government related identifier can be adopted, used and disclosed.

Australian Privacy Principles

Part 4 — Integrity of personal information

- **APP10: quality of personal information**

- The entity must ensure the quality (accuracy, completeness and timeliness) of data in both collection and usage or disclosure phases.

- **APP11: security of personal information**

- The entity must take steps to protect personal information from misuse, loss, or unauthorized access.
- The entity must take steps to destroy the needless information or to ensure that the information is de-identified.

Australian Privacy Principles

Part 5 — Access to, and correction of, personal information

- **APP12: access to personal information**

- Ensures that individual can access his/her personal information stored on entity's side except with some special circumstances.

- **APP13: correction of personal information**

- Outlines the steps that an entity should do to correct the personal information.

Medibank Data Breach

- In October 2022, Medibank experienced a major data breach affecting 9.7 million current and former customers, resulting in the release of personal information on the dark web, leading to investigations and potential legal action.
- The Australian Information Commissioner alleges Medibank seriously interfered with the privacy of 9.7 million Australians by failing to take reasonable steps to protect their personal information from misuse and unauthorised access or disclosure in breach of the **Privacy Act 1988**.
- The Federal Court can impose a civil penalty of up to \$2.22 million for each contravention.

Cyber Security Act 2024

- Issued On 29 November 2024.
- The act addresses the gap to bring Australia in line with international best practice, ensuring Australia is on track to become a global leader in cyber security.
- It implements 4 **initiatives** under the **2023-2030 Australian Cyber Security Strategy**:
 - mandate **minimum cyber security standards** for smart devices;
 - introduce a **mandatory ransomware and cyber extortion reporting obligation** for certain businesses to report ransom payments;
 - introduce a **Limited Use obligation for the National Cyber Security Coordinator** to encourage industry engagement with the government following cyber incidents;
 - establish a **Cyber Incident Review Board** to conduct reviews of significant cyber incidents and share lessons learned.

Security Standards for Smart Devices

- Part 2 of the Cyber Security Act 2024 prescribe rules that will establish mandatory security standards for smart devices, also known as Internet of Things (IoT) devices.
- The Act places responsibility on manufacturers and suppliers of smart devices to ensure that those devices meet requirements in the specified security standard relevant to that product if there is intent for that device to be made available in Australia.
- Manufacturers and suppliers need to produce a statement of compliance to claim that their device meets the requirement under relevant standard, including:
 - ✓ produce type and batch identifier
 - ✓ name and address of each manufacturer of the device,
 - ✓ a declaration that the device is made in compliance with requirement of security standard,
 - ✓ ...

Mandatory Ransomware Payment Reporting

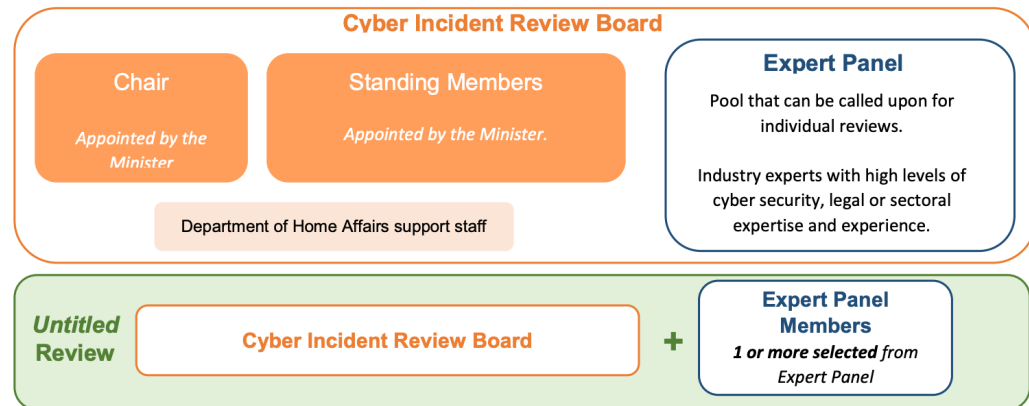
- Part 3 of the Cyber Security Act 2024 establishes a ransomware and cyber extortion payment reporting obligation on reporting business entities.
- By doing this, the Australian Government will be able to build a more informed picture of the threat landscape and provide tailored advice and support to industry to help disrupt the ransomware business model.
- An **entity** will be a reporting business entity if it:
 - is carrying on business in Australia with an annual turnover that exceeds the turnover threshold specified in the Rules; and
 - is not a Commonwealth body or a State body.
- A reporting business entity must make a report within 72 hours of making the ransomware payment (or becoming aware that the ransomware payment has been made). Otherwise, a civil penalty of 60 penalty units (\$19,800) can be applied.

Cyber Incident Review Board

- Establishment of the **Cyber Incident Review Board** (the Board) as an independent statutory advisory body
 - to conduct no-fault, post-incident reviews of significant cyber security incidents in Australia and make recommendations to Government and industry about actions that could be taken to prevent, detect, respond to, or minimise the impact of cyber security incidents of a similar nature in the future.

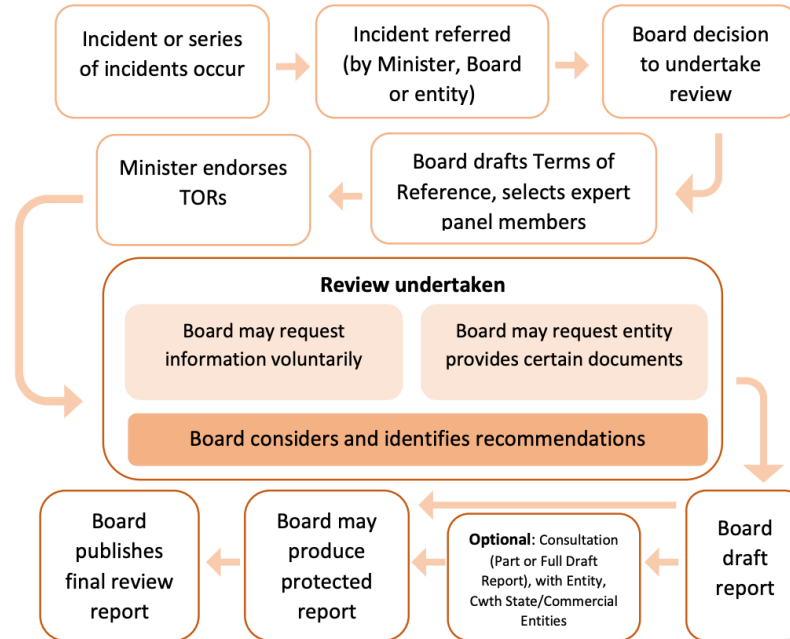
- Composition of Board

Operation



Cyber Incident Review Board

Review Process



2023-2030 Australian Cybersecurity Strategy

- By 2030, Australia will be a world leader in cyber security.
 - The Strategy is the roadmap that will help realise the Australian Government's vision by 2030.
- The strategy addresses six cyber shields which will be used to protect Australians.

Figure 1: Cyber shields



2023-2030 Australian Cybersecurity Strategy

- For each shields, there are some proposed initiatives that will be done by Australian government to achieve the 2030 vision.
- Shield 1: Strong business and citizens
 - support small and medium businesses to strengthen their cyber security;
 - help Australians defend themselves from cyber threats;
 - disrupt and deter cyber threat actors from attacking Australia;
 - **work with industry to break the ransomware business model;**
 - provide clear cyber guidance for businesses;
 - **make it easier for businesses to access advice and support after a cyber incident;** and
 - secure our identities and provide better support to victims of identity theft.

2023-2030 Australian Cybersecurity Strategy

- **Shield 2: Safe Technology**

- **ensure Australians can trust their digital products and software;**
- protect our most valuable datasets; and
- promote the safe use of emerging technology

- **Shield 3: World-class threat sharing and blocking**

- create a whole-of-economy threat intelligence network; and
- scale threat-blocking capabilities to stop cyber attacks.

- **Shield 4: Protected critical infrastructure**

- clarify the scope of critical infrastructure regulation;
- strengthen cyber security obligations and compliance for critical infrastructure;
- uplift cyber security of the Commonwealth Government; and
- **pressure-test our critical infrastructure to identify vulnerabilities.**

2023-2030 Australian Cybersecurity Strategy

- **Shield 5: Sovereign capabilities**

- grow and professionalise our national cyber workforce; and
- accelerate our local cyber industry, research and innovation.

- **Shield 6: Resilient region and global leadership**

- support a cyber resilient region as the partner of choice; and
- shape, uphold and defend international cyber rules, norms and standards.